



**COMPOSABLE
SECURITY**

REPORT

Security consultation for Lido

Prepared by: Composable Security

Report ID: LDO-2b29cfdc

Test time period: 2026-07-26 - 2026-07-28

Report date: 2026-07-28

Version: 1.0

Visit: composable-security.com

Contents

1. Security consultation summary (2026-07-28)	2
1.1 Subject of Consultation	2
1.2 Scope	2
1.3 Issues	2
1.4 Consultation Results	3
1.5 Deployments	3
1.6 Disclaimer	3

1. Security consultation summary (2026-07-28)

1.1. Subject of Consultation

The **Composable Security** team was engaged by **Lido** to perform a focused security review of changes introduced in Lido Oracle version **8.0.5**, including:

- handling of operator groups in which all internal Curated Module v2 node operators have zero weight,
- additional Keys API consistency checks,
- handling of critical key-count discrepancies and possible validator deposit front-running,
- diagnostic logging for pending deposits using Lido withdrawal credentials.

1.2. Scope

The assessment focused on changes introduced in version **8.0.5**.

GitHub repository:

<https://github.com/lidofinance/lido-oracle>

CommitID: 2b29cfdc7e3c8678fda7fa63e3ec78f4aa370f70

1.3. Issues

1.3.1 Potentially misleading warning for subsequent pending deposits

The newly introduced `_kapi_sanity_check_pending_deposits` function logs pending deposits that use Lido withdrawal credentials but whose public keys are not present among the used keys returned by Keys API.

The check considers each pending deposit separately. Therefore, a warning may be emitted when a deposit using Lido withdrawal credentials is not the first valid deposit for the public key. In such a case, the validator's withdrawal credentials may already have been determined by an earlier deposit using non-Lido withdrawal credentials.

Consequently, the warning does not always indicate that Keys API omitted a required Lido key and may create unnecessary operational noise.

The issue does not affect Oracle calculations or report production because the check is diagnostic-only.

The Resolution

The behaviour was discussed with the project team and left unchanged in version **8.0.5**.

The warning remains diagnostic-only, and the project noted the case for potential refinement in a future major release.

1.4. Consultation Results

The reviewed changes correctly handle operator groups in which the combined internal weight is zero.

In this situation, external stake is distributed according to the configured operator shares instead of operator weights. The same rule is applied when stake is reduced after an external validator exit. Additional guards prevent division by zero when the total module weight is zero.

The update also introduces two Keys API consistency checks:

- a global check verifying that Keys API returned at least as many used keys as there are deposited validators,
- a per-operator check verifying that every required deposited-key index is present.

When a required key is missing, the Oracle raises `CountOfKeysDiffersException`. A possible validator deposit front-running incident raises `FrontRunAttackError`.

Both exceptions stop the Oracle daemon and prevent report production until the incident is investigated and resolved manually. This behaviour is intentional and appropriate for critical inconsistencies affecting validator accounting.

The per-operator check does not reject additional Keys API entries because Keys API may return data from a block newer than the Oracle reference block.

Apart from the diagnostic warning described above, no additional security issues were identified in the reviewed changes.

1.5. Deployments

After the security review conducted, we verified that the Dockerfile used to build an image uses the reviewed source code. The published image with the manifest digest

sha256:456bbfe023b75ce67b0939cee3be31673a2d65ce7c0b106c13ec3762a4298592

corresponds to the commitID: **2b29cfdc7e3c8678fda7fa63e3ec78f4aa370f70**.

1.6. Disclaimer

Security consultation **IS NOT A SECURITY WARRANTY**.

During the review, the Composable Security team makes every effort to detect any occurring problems and help to address them. However, it is not allowed to treat the report as a security certificate and assume that the project does not contain any vulnerabilities. Securing applications is a multi-stage process.

Therefore, we encourage the implementation of security mechanisms at all stages of development and maintenance.



Damian Rusinek

Smart Contracts Auditor

@drdr_{zz}

damian.rusinek@composable-security.com



Paweł Kuryłowicz

Smart Contracts Auditor

@wh01s7

pawel.kurylowicz@composable-security.com

